

CAPÍTULO 6

El Riesgo en la Era Cuantitativa

Metodologías de análisis, justificación financiera, monitoreo continuo y amenazas emergentes de 2026

MAGERIT · OCTAVE · FAIR · ROSI · CRQM · Tres Líneas de Defensa

Resumen

Este capítulo aborda la transición desde la evaluación cualitativa del riesgo hacia su cuantificación financiera y su monitoreo continuo, un movimiento que define la práctica profesional contemporánea de la gestión de riesgos de tecnologías de la información. Tras argumentar por qué el juicio cualitativo resulta insuficiente para sustentar decisiones de inversión ante un comité directivo, se examina el ecosistema de metodologías de análisis dominante en el ámbito iberoamericano —MAGERIT, OCTAVE Allegro y FAIR— y se propone su articulación en un patrón profesional integrado de tres niveles. El capítulo desarrolla luego el aparato económico que traduce el riesgo al lenguaje del negocio: la pérdida anual esperada, el retorno sobre la inversión en seguridad y la distinción entre riesgo inherente y residual. A continuación se aborda la dimensión temporal del riesgo —su carácter dinámico y la obsolescencia de la evaluación estática— y la arquitectura de cuantificación y monitoreo continuo que responde a ella, junto con el modelo de gobernanza de las tres líneas de defensa. El capítulo cierra mapeando las amenazas emergentes del horizonte de 2026 —la inteligencia artificial generativa, la nube hiperescalada y la cadena de suministro de software— con sus controles estratégicos, y sostiene que el desafío no exige nuevos marcos, sino la integración de nuevas telemetrías a la metodología existente. Los conceptos se anclan en evidencia empírica reciente y en el marco normativo peruano.

Palabras clave: *cuantificación del riesgo, FAIR, MAGERIT, OCTAVE, ROSI, riesgo residual, monitoreo continuo, tres líneas de defensa, amenazas emergentes.*

6.1 Introducción: el mandato de cuantificar

El capítulo anterior diseccionó la anatomía de un sistema moderno de gestión de riesgos: sus marcos de gobierno, sus indicadores, sus herramientas de evaluación y su integración en un ecosistema de capas. Esa disección, sin embargo, era todavía estática; describía la estructura del sistema, pero no su comportamiento en el tiempo ni su capacidad de sustentar decisiones de inversión. Este capítulo introduce ambas dimensiones, articuladas en torno a una tesis ejecutiva: el riesgo no se gestiona con colores, se gestiona con evidencia, y esa evidencia debe ser tanto financiera como continua.

El punto de partida es una escena familiar para cualquier responsable de seguridad. Un profesional solicita ante un comité directivo un presupuesto considerable para un programa de ciberseguridad. El director financiero pregunta por qué esa cifra y no otra, y qué ocurriría si no se invirtiera nada. La respuesta de que el riesgo es «alto» o de que «está en rojo» en la matriz no consigue el presupuesto, porque un color no es una cantidad y una categoría ordinal no se traduce en soles. Como se mostró en el capítulo precedente al examinar los puntos ciegos de la matriz 5×5, la evaluación cualitativa adolece de una ilusión de precisión que la inhabilita para comparar el riesgo cibernético con el resto del portafolio de riesgos de una organización (Cox, 2008).

El mandato de la era cuantitativa es, precisamente, reemplazar el instinto por la cuantificación. Esto no supone descartar el juicio experto —que conserva su valor para la identificación inicial—, sino hacer explícitas las estimaciones, expresarlas como rangos calibrados y propagarlas mediante métodos estadísticos hasta producir un resultado auditable y defendible. La autoridad metodológica de Hubbard y Seiersen (2023) es aquí pertinente: prácticamente todo en el riesgo de ciberseguridad es medible si se acepta que medir significa reducir la incertidumbre, no eliminarla. El recorrido del capítulo desarrolla este programa: primero las metodologías que producen el análisis, luego el aparato que lo traduce a dinero, después la arquitectura que lo mantiene vivo en el tiempo y, finalmente, las amenazas que ponen a prueba todo el sistema.

6.2 Del juicio cualitativo al rigor financiero

La distinción entre los enfoques cualitativo y cuantitativo de la evaluación del riesgo, esbozada en el capítulo anterior, merece ahora un tratamiento más fino. Resulta útil pensar en tres niveles de madurez analítica. El primer nivel, el enfoque subjetivo, descansa en el juicio experto: es rápido,

económico y adecuado para talleres de identificación, pero indefendible ante un comité financiero, porque la etiqueta «riesgo alto» no se traduce en presupuesto. El tercer nivel, el enfoque cuantitativo, expresa el riesgo como una distribución monetaria con percentiles, convirtiéndolo al lenguaje del negocio: el impacto financiero real.

Entre ambos existe un nivel intermedio que conviene nombrar explícitamente: el enfoque semicuantitativo, que asigna valores numéricos a las escalas ordinales —por ejemplo, traduciendo «impacto moderado» a un rango de pérdida de 50 000 a 500 000 soles—. Este nivel intermedio es el terreno natural de metodologías como OCTAVE y constituye un puente pedagógico valioso, pues introduce la disciplina de la cuantificación sin la exigencia de datos del análisis pleno. El profesional rara vez opera en un polo puro; navega el continuo completo según la decisión que deba sustentar.

La representación cuantitativa no entrega un número único —que sería tan engañoso como un color—, sino una distribución. Una curva de pérdida típica expresa, por ejemplo, una pérdida mediana en el percentil 50 acompañada de un percentil 10 que marca el escenario optimista y un percentil 90 que marca el adverso. Esta forma de comunicar el riesgo admite ser comparada directamente con cualquier otra decisión financiera de la organización, y por ello es la que un director financiero o un comité de auditoría pueden incorporar a sus deliberaciones sin necesidad de traducción. Conviene, no obstante, una advertencia honesta: lo cuantitativo no es «más verdadero» que lo cualitativo en sentido absoluto, pues sus insumos siguen siendo estimaciones; lo que cambia es que esas estimaciones se hacen transparentes, se expresan como rangos y se vuelven auditables.

6.3 El ecosistema metodológico: MAGERIT, OCTAVE y FAIR

Tres metodologías dominan la práctica del análisis de riesgo en el ámbito iberoamericano, y conviene entenderlas no como alternativas excluyentes, sino como herramientas complementarias que responden a preguntas distintas. La elección entre ellas —o su combinación— depende del objetivo del análisis, de la audiencia a la que se dirige y de los recursos disponibles.

6.3.1 MAGERIT v3: la cobertura exhaustiva

MAGERIT —Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información— fue desarrollada por el Consejo Superior de Administración Electrónica de España y constituye,

de hecho, la metodología de referencia en el sector público iberoamericano (Ministerio de Hacienda y Administraciones Públicas, 2012). Su rasgo distintivo es la exhaustividad: descansa en catálogos masivos que clasifican los activos en capas —datos, servicios, software, equipos, soportes, instalaciones y personal— y enumeran de manera sistemática las amenazas que afectan a cada uno y las salvaguardas aplicables. Produce un mapa completo del riesgo, acompañado de códigos que facilitan la trazabilidad y la auditoría.

La fortaleza de MAGERIT —su cobertura total— es también su costo: un análisis riguroso puede extenderse durante semanas o meses. Por ello su nicho natural es el cumplimiento normativo y la auditoría, donde la exigencia de completitud documental justifica la inversión de tiempo. Su pregunta característica es «¿qué tenemos?», y su audiencia ideal son los oficiales de cumplimiento. Para una entidad pública peruana sujeta al Modelo de Seguridad Digital del Estado, MAGERIT ofrece el nivel de detalle que un órgano de control espera encontrar (Presidencia del Consejo de Ministros, 2020).

6.3.2 OCTAVE Allegro: el foco selectivo

OCTAVE —Operationally Critical Threat, Asset, and Vulnerability Evaluation— fue desarrollada por el Software Engineering Institute de la Universidad Carnegie Mellon, y su variante Allegro es deliberadamente ágil (Caralli et al., 2007). Su filosofía es inversa a la de MAGERIT: en lugar de inventariar todo, se concentra exclusivamente en los activos de información cuya pérdida amenazaría la misión de la organización. No pregunta «¿qué tenemos?», sino «¿qué es verdaderamente crítico?». Por ello se ejecuta en talleres intensivos de dos o tres días, liderados por los propios gestores operativos que conocen el negocio, y no por consultores externos.

El nicho de OCTAVE es la priorización ágil y los talleres ejecutivos: resulta idónea cuando la organización necesita resultados rápidos y accionables, y cuando se busca que el riesgo sea propiedad del negocio y no un ejercicio delegado al área técnica. Su limitación es la cara opuesta de su virtud: al ser selectiva, puede dejar fuera del radar activos que parecían secundarios y resultaron no serlo. Su audiencia ideal son los gestores operativos.

6.3.3 FAIR: la cuantificación financiera

FAIR —Factor Analysis of Information Risk—, introducido en el capítulo anterior, ocupa un lugar específico en este ecosistema: es la única de las tres que produce una salida estrictamente

financiera. Adoptado por The Open Group como estándar O-RT (taxonomía) y O-RA (análisis), descompone el riesgo en frecuencia de eventos de pérdida y magnitud de pérdida, y los modela como distribuciones estadísticas para entregar una curva monetaria con percentiles que van del 10 al 90 (The Open Group, 2021). Su pregunta característica es «¿cuánto perderemos?», y su audiencia natural son los comités de auditoría, los directores financieros y las decisiones de alta inversión. El Cuadro 6.1 sintetiza la comparación de las tres metodologías.

Cuadro 6.1

Anatomía comparada de las tres metodologías de análisis de riesgo

Dimensión	MAGERIT v3	OCTAVE Allegro	FAIR
Enfoque	Exhaustivo	Selectivo	Financiero
Salida principal	Mapa completo y códigos	Plan enfocado en activos críticos	Distribución monetaria
Duración típica	Semanas a meses	Talleres de 2 a 3 días	Semanas por escenario
Audiencia ideal	Oficiales de cumplimiento	Gestores operativos	Junta directiva (CFO, CISO)
Pregunta clave	¿Qué tenemos?	¿Qué es crítico?	¿Cuánto perderemos?

Nota. Elaboración a partir de Ministerio de Hacienda y Administraciones Públicas (2012), Caralli et al. (2007) y The Open Group (2021).

6.3.4 El patrón profesional integrado

La aparente tensión entre las tres metodologías se resuelve al comprender que sus preguntas no compiten, sino que se encadenan en una secuencia lógica representable como un embudo. MAGERIT actúa como el cimiento: establece el mapa de cobertura total e identifica y categoriza todo el inventario tecnológico y sus amenazas fundamentales. OCTAVE funciona como el lente crítico: filtra el ruido y selecciona únicamente la información tan crítica que su compromiso paralizaría el negocio. FAIR opera como el motor de decisión: aplica rigor matemático solo a los escenarios críticos ya filtrados y entrega la justificación financiera para la inversión en mitigación. La síntesis es clara: las tres no compiten, sino que MAGERIT aporta la escala, OCTAVE aporta el foco y FAIR aporta el presupuesto.

Este patrón formaliza y precisa la regla del uso combinado expuesta en el capítulo anterior: aplicar primero la herramienta amplia y económica, aislar el subconjunto crítico y reservar el método costoso y profundo para ese subconjunto. La economía de esfuerzo es evidente, pues aplicar rigor cuantitativo a la totalidad de los activos sería tan oneroso como inútil. El embudo no debe leerse, sin embargo, como una secuencia rígida: en organizaciones con recursos muy

limitados —como muchas entidades de regiones del interior del país— es legítimo comenzar por OCTAVE para identificar de inmediato los pocos activos vitales y reservar la exhaustividad de MAGERIT para una fase posterior. Lo esencial no es el orden cronológico, sino que las tres funciones —escala, foco y presupuesto— estén presentes en algún momento del ciclo.

6.4 El idioma del negocio: la justificación de la inversión

Si FAIR entrega el presupuesto, falta precisar cómo una distribución de pérdida se convierte en un argumento que un comité financiero apruebe. La respuesta es el retorno sobre la inversión en seguridad, métrica conocida por su sigla inglesa ROSI, que articula tres componentes: la pérdida anual esperada, el poder de mitigación de un control y el costo de ese control.

6.4.1 La pérdida anual esperada (ALE)

El ALE —Annualized Loss Expectancy— es el producto de dos factores clásicos del análisis cuantitativo. El primero es el SLE —Single Loss Expectancy o pérdida esperada por evento único—, que estima el costo de una sola materialización del riesgo. El segundo es el ARO —Annualized Rate of Occurrence o frecuencia anualizada de ocurrencia—, que estima cuántas veces al año cabe esperar el evento. Su producto, $ALE = SLE \times ARO$, expresa la pérdida que, en promedio, la organización debe esperar absorber cada año por ese riesgo si no adopta ninguna medida.

Conviene subrayar que el ALE es una esperanza estadística, no una predicción. Si el ALE de un riesgo es de 150 000 soles anuales, ello no significa que la organización perderá exactamente esa suma este año, sino que, promediando a lo largo de muchos años, esa es la pérdida media anual atribuible al riesgo. Un año puede no ocurrir nada y otro puede sobrevenir una pérdida grave; el ALE es la cifra que permite comparar y presupuestar, no adivinar el futuro de un ejercicio concreto.

6.4.2 El poder de mitigación y el cálculo del ROSI

Ningún control reduce el riesgo a cero. El poder de mitigación expresa qué fracción del riesgo neutraliza un control determinado, y la práctica rigurosa exige que esa reducción sea comprobable: no basta afirmar que un control «mejora la seguridad», sino que debe estimarse, con base en evidencia o en juicio calibrado, cuánto del riesgo elimina. El costo del control es la inversión total —adquisición, implementación y operación— necesaria para obtener ese poder de mitigación. Con

estos tres elementos se calcula el retorno sobre la inversión en seguridad mediante la fórmula siguiente:

$$ROSI = [(ALE \times \text{poder de mitigación}) - \text{costo del control}] \div \text{costo del control}$$

Un ejemplo concreto ilustra el procedimiento. Supóngase un riesgo con un ALE de 150 000 soles, un control —combinación de detección y respuesta en el endpoint con respaldos— que reduce el riesgo en un 80 % y cuesta 25 000 soles. El beneficio bruto del control es $150\,000 \times 0,80 = 120\,000$ soles de pérdida evitada al año; restando el costo de 25 000 se obtiene un beneficio neto de 95 000 soles; dividiendo entre el costo se obtiene 3,8, es decir, un retorno del 380 %. La lectura ejecutiva es inmediata y persuasiva: cada sol invertido evita casi cuatro soles en pérdidas operativas. Esta es la clase de enunciado que un comité financiero puede evaluar y aprobar, y constituye la traducción del resultado de un análisis FAIR al lenguaje del retorno que la dirección utiliza para juzgar cualquier inversión.

6.5 Riesgo inherente, riesgo residual y la decisión de negocio

La aplicación de controles transforma el riesgo, pero no lo elimina. El riesgo inherente es el nivel de riesgo en ausencia de controles —el riesgo «en bruto»—, mientras que el riesgo residual es lo que permanece después de aplicar la mitigación. Retomando el ejemplo anterior, un riesgo inherente de 150 000 soles que se reduce en un 80 % deja un riesgo residual de 30 000 soles; esa diferencia de 120 000 es, precisamente, el beneficio bruto que alimentaba el cálculo del ROSI, de modo que ambas nociones describen el mismo fenómeno desde ángulos complementarios.

El punto conceptual decisivo es que el riesgo residual nunca es cero. Pretender eliminarlo por completo es económicamente irracional —el costo de los últimos puntos porcentuales de reducción crece de forma desproporcionada— y técnicamente imposible. La pregunta correcta no es cómo eliminar el riesgo, sino qué hacer con el que inevitablemente permanece; y esa es una decisión de negocio, no técnica. La tesis que organiza esta sección lo formula sin ambages: el riesgo residual no es un fallo técnico, sino una decisión de negocio.

Frente al riesgo residual se abren cuatro caminos, que dialogan con las cuatro estrategias de tratamiento examinadas en el capítulo anterior. La aceptación formal consiste en retener el residual mediante un documento firmado por la autoridad ejecutiva, con una vigencia máxima de doce

meses; el requisito de la firma y del plazo no es burocracia, sino lo que distingue la aceptación consciente —válida ante una auditoría— de la simple desidia, y lo que obliga a revisar periódicamente una decisión que el cambio del entorno puede volver obsoleta. El tratamiento adicional implementa controles de compensación complementarios cuando el residual sigue excediendo el apetito, en un nuevo ciclo coherente con el carácter iterativo del proceso ISO 31000. La transferencia contrata pólizas de seguro cibernético para el residuo inaceptable, recordando que el seguro traslada el costo financiero, no la responsabilidad reputacional ni regulatoria. La reevaluación continua monitorea trimestralmente el residual ante cambios en las amenazas, y constituye la bisagra hacia la dimensión dinámica del riesgo que se aborda a continuación.

El requisito de que la aceptación la firme la autoridad ejecutiva encierra, además, una lección de gobernanza: el área técnica identifica, mitiga y mide, pero la decisión de convivir con un riesgo residual —que es una apuesta de negocio— corresponde a quien tiene la autoridad y rinde cuentas por los resultados. Este principio anticipa el modelo de gobernanza que se examina más adelante.

6.6 La ilusión del riesgo estático

Una evaluación de riesgo es una fotografía tomada en un instante, y como toda fotografía envejece. La tesis central de esta sección es que una matriz de riesgo anual caduca el día en que se imprime, porque tres fuerzas erosionan continuamente la validez de la evaluación a medida que el tiempo transcurre.

La primera fuerza es externa: el entorno cambia. El repositorio nacional de vulnerabilidades registró alrededor de 40 000 vulnerabilidades CVE publicadas en 2024 —un incremento del 38 % respecto del año anterior— y cerca de 48 000 en 2025, lo que equivale a más de 130 vulnerabilidades nuevas cada día (CVE.ICU, 2025; Statista, 2026). A ello se suman nuevas tácticas adversariales y nuevas regulaciones. Cada vulnerabilidad que afecta a un activo de la organización altera el cálculo de riesgo realizado el año anterior. La segunda fuerza es interna y estructural: la organización cambia. La adopción de nuevos proveedores amplía la superficie de exposición, la expansión tecnológica multiplica los activos y la elevada rotación del personal de tecnología —que suele situarse entre el 30 % y el 40 %— se lleva consigo el conocimiento tácito y deja, en ocasiones, accesos sin revocar. La organización evaluada doce meses atrás ya no existe en los mismos términos.

La tercera fuerza es la más insidiosa porque opera en silencio: los controles se degradan. La desviación de configuraciones, o control drift, afecta a una proporción sustancial de los controles —políticas que se olvidan, configuraciones que se relajan, autenticación multifactor que alguien desactiva por conveniencia—. Un control que el año pasado funcionaba puede haber dejado de hacerlo sin que nadie lo decidiera conscientemente. La degradación es entrópica: el estado seguro requiere energía para mantenerse y, en su ausencia, el sistema tiende al desorden. La consecuencia conjunta de las tres fuerzas es contundente: quien gestiona el riesgo de forma anual toma decisiones de hoy con datos de hace doce meses. La solución no consiste en producir mejores fotografías, sino en pasar al video, esto es, al monitoreo continuo.

6.7 La arquitectura de cuantificación y monitoreo continuo

La respuesta operativa a la obsolescencia de la evaluación estática es la arquitectura de cuantificación y monitoreo continuo del riesgo, conocida por su sigla inglesa CRQM. Se la puede concebir como un ciclo de cuatro estaciones encadenadas que mantienen la medición del riesgo permanentemente actualizada.

La primera estación es la recolección automática: telemetría viva proveniente de los sistemas de gestión de eventos de seguridad, de las herramientas de detección y respuesta en el endpoint, de la base de datos de configuración y de los feeds de inteligencia de amenazas. El carácter automático de esta recolección elimina la intervención manual que hacía del análisis anual algo costoso e infrecuente. La segunda estación es la normalización: el mapeo de los eventos recolectados contra marcos globales —el NIST Cybersecurity Framework y la matriz MITRE ATT&CK— para crear un idioma común; sin esta traducción, los datos de fuentes heterogéneas constituirían una torre de Babel incapaz de alimentar un cálculo coherente (NIST, 2024).

La tercera estación es el modelado cuantitativo: la aplicación algorítmica de FAIR para recalcular el impacto financiero —el ALE— en tiempo real, de modo que la cuantificación deja de ser un ejercicio puntual y se convierte en un cálculo permanente que se actualiza con cada nuevo dato. La cuarta estación es la visualización ejecutiva: tableros en vivo con alertas automáticas que se disparan cuando el riesgo cruza el umbral de apetito aprobado por la junta. Este vínculo entre la operación técnica de la recolección y la gobernanza estratégica de la decisión sobre cuánto riesgo tolerar cierra el lazo entre quienes miden y quienes deciden. El CRQM es, en rigor, la

materialización concreta de la capa fundacional del ecosistema híbrido descrito en el capítulo anterior.

6.8 La gobernanza del riesgo: las tres líneas de defensa

La medición continua del riesgo carece de efecto si no se inserta en una estructura de gobernanza que asigne con claridad responsabilidades. El modelo de las tres líneas de defensa, promovido por el Instituto de Auditores Internos, cumple esa función al distinguir tres roles complementarios e independientes (Institute of Internal Auditors, 2020).

La primera línea es la defensa operativa, integrada por los dueños de procesos y los equipos de tecnología y operaciones. Implementan los controles diarios, son los propietarios del riesgo y constituyen la primera instancia de identificación; es donde el riesgo vive y donde primero se detecta. La segunda línea es la de supervisión y cumplimiento, integrada por el responsable de seguridad de la información y los oficiales de riesgo. No operan los controles: diseñan las políticas, monitorean los indicadores —el CRQM es su instrumento— y asesoran a la línea operativa, en una función de arquitectura del marco. La tercera línea es la auditoría independiente, integrada por la auditoría interna y los organismos de control, cuya función es la evaluación independiente con reporte directo y sin filtros a la junta directiva.

La separación de estas líneas no es un formalismo. El error de gobernanza más común consiste en confundirlas: que quien opera un control sea también quien lo audita, o que el responsable de seguridad acepte por su cuenta riesgos que corresponden a la dirección —precisamente lo que la exigencia de firma ejecutiva sobre el riesgo residual previene—. El valor de la tercera línea reside en su independencia: no diseña ni opera, sino que observa y verifica, lo que le permite detectar lo que las otras dos, por estar implicadas, no pueden ver de sí mismas. En el contexto peruano, esta estructura se alinea con la lógica de los órganos de control institucional del sector público.

6.9 El horizonte de 2026: amenazas emergentes y su control

El sistema de gestión de riesgos construido a lo largo del capítulo se enfrenta, en 2026, a tres amenazas que comparten un rasgo: rompen los supuestos sobre los que se edificaron las defensas tradicionales. No son hipótesis, sino vectores que ya producen incidentes documentados.

6.9.1 Inteligencia artificial generativa

La amenaza presenta dos caras. La primera es la fuga de propiedad intelectual al alimentar modelos de lenguaje públicos: cuando un empleado introduce código fuente, contratos o datos personales en un asistente de inteligencia artificial público, esa información puede escapar del perímetro de control de la organización. La segunda son los ataques de falsificación sintética —deepfakes— para la suplantación de directivos y el fraude financiero; la falsificación de voz y video permite, por ejemplo, simular la orden de un ejecutivo para autorizar una transferencia. El caso de una multinacional en Hong Kong, donde un empleado transfirió el equivalente a 25 millones de dólares tras una videollamada en la que el resto de los participantes eran deepfakes, demuestra que el vector ya causó pérdidas reales.

El control estratégico combina dos medidas. La generación aumentada por recuperación sobre modelos de lenguaje privados permite aprovechar la inteligencia artificial sin exponer datos a servicios públicos, pues el modelo consulta una base de conocimiento interna y controlada. La prevención de pérdida de datos, apoyada en algoritmos de clasificación de la información, detecta y bloquea la salida de datos sensibles. En el contexto peruano, el tratamiento de datos personales mediante asistentes públicos sin base legal compromete la Ley N.º 29733, lo que añade una dimensión regulatoria a la técnica (Congreso de la República del Perú, 2011).

6.9.2 Nube hiperescalada

La amenaza no reside en la nube en sí, sino en los errores de configuración de la gestión de identidades y accesos que provocan exposición masiva de datos. El concepto clave es el radio de explosión: en una infraestructura compartida, un solo error de configuración de permisos puede exponer no un servidor, sino millones de registros a la vez. La escala de la nube, que es su virtud operativa, se convierte en su mayor riesgo cuando un permiso mal asignado abre una puerta de dimensiones desproporcionadas. El control estratégico es la gestión de la postura de seguridad en la nube, que monitorea de forma continua las configuraciones para detectar errores antes de que se exploten —una aplicación del CRQM al entorno de nube—, complementada por la infraestructura inmutable, que impide los cambios manuales reemplazando los componentes en lugar de modificarlos y neutraliza así la desviación de configuraciones.

6.9.3 Cadena de suministro de software

La tercera amenaza es quizá la más difícil de contener, porque ataca la confianza misma. El compromiso se produce a través de proveedores de software de terceros y de componentes de código abierto: el ataque no entra por la puerta principal —que la organización vigila—, sino por los contratistas y las dependencias en las que confía. Basta comprometer un eslabón de la cadena para alcanzar a todos los que dependen de él, de modo que la organización mejor defendida puede caer por una vulnerabilidad en una biblioteca de código que ignoraba estar utilizando. El control estratégico exige la lista de materiales de software —un inventario de todos los componentes y dependencias de una aplicación que obliga al proveedor a transparentar de qué está hecho su software— y la fijación estricta de versiones, que impide que una dependencia se actualice automáticamente a una versión comprometida.

6.9.4 La tesis: integrar telemetrías, no cambiar de marco

El mensaje estratégico que cierra el bloque es a la vez tranquilizador y exigente. No se requieren nuevos marcos de riesgo: ISO 31000, MAGERIT, OCTAVE y FAIR siguen siendo válidos. Lo que se requiere es integrar nuevas telemetrías a la metodología existente —datos de uso de inteligencia artificial, de configuración de nube, de composición de software— que hace apenas unos años no existían. La metodología es estable; los sensores deben evolucionar. El Cuadro 6.2 sintetiza el mapeo entre cada amenaza emergente y su control estratégico.

Cuadro 6.2

Amenazas emergentes de 2026 y sus controles estratégicos

Amenaza emergente	Control estratégico (defensa)
IA generativa	RAG corporativo y DLP. Aislamiento de modelos mediante LLM privados y prevención de pérdida de datos con clasificación de la información.
Nube hiperescalada	CSPM e inmutabilidad. Monitoreo continuo de la postura en la nube e infraestructuras inmutables que bloquean los cambios manuales.
Cadena de suministro	SBOM y fijación de versiones. Exigencia contractual de una lista de materiales de software y fijación estricta de las versiones de las dependencias.

Nota. Amenazas emergentes y los controles recomendados.

6.10 El mandato ejecutivo y reflexión final

Todo el recorrido del capítulo puede condensarse en tres preguntas que un directivo responsable debería poder responder, y que recorren en orden los grandes bloques del capítulo. La pregunta financiera interroga si las decisiones de inversión en ciberseguridad se basan en juicios de valor expresados en colores o en proyecciones monetarias defendibles. La pregunta de visibilidad interroga si los mapas de riesgo caducan el día en que se imprimen o si la organización cuenta con un radar continuo que la alerte antes del impacto. La pregunta de preparación interroga si, dado que la inteligencia artificial generativa y la nube transforman hoy el negocio, los modelos de riesgo de ayer están capacitados para proteger el mañana.

Referencias bibliográficas

- Caralli, R. A., Stevens, J. F., Young, L. R., & Wilson, W. R. (2007). *Introducing OCTAVE Allegro: Improving the information security risk assessment process* (CMU/SEI-2007-TR-012). Software Engineering Institute, Carnegie Mellon University.
- Congreso de la República del Perú. (2011). *Ley N.º 29733, Ley de Protección de Datos Personales*. Diario Oficial El Peruano.
- Cox, L. A. (2008). What's wrong with risk matrices? *Risk Analysis*, 28(2), 497–512. <https://doi.org/10.1111/j.1539-6924.2008.01030.x>
- CVE.ICU. (2025). *2024 CVE data review*. <https://www.cve.icu>
- Hubbard, D. W., & Seiersen, R. (2023). *How to measure anything in cybersecurity risk* (2.ª ed.). Wiley.
- Institute of Internal Auditors. (2020). *The IIA's three lines model: An update of the three lines of defense*. The Institute of Internal Auditors.
- International Organization for Standardization. (2018). *ISO 31000:2018. Risk management — Guidelines*. ISO.
- Jones, J. A. (2005). *An introduction to Factor Analysis of Information Risk (FAIR)*. Risk Management Insight.
- Ministerio de Hacienda y Administraciones Públicas. (2012). *MAGERIT versión 3.0. Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información*. Gobierno de España.
- National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0*. U.S. Department of Commerce.
- Presidencia del Consejo de Ministros. (2020). *Resolución de Secretaría de Gobierno Digital N.º 005-2020-PCM/SEGDI. Modelo de Seguridad Digital del Estado Peruano*. Diario Oficial El Peruano.
- Statista. (2026). *Number of common IT security vulnerabilities and exposures (CVEs) worldwide*. Statista Research Department.
- The Open Group. (2021). *Open FAIR body of knowledge: Risk taxonomy (O-RT) and risk analysis (O-RA) standards*. The Open Group.